

12



Módulo 12

Resposta a incidentes e protocolos seguros

Aula 03

Resposta a Incidentes

Introdução —

Nesta aula, você conhecerá os seguintes assuntos:

- As fases do tratamento de incidente;
- Fontes de dados apropriadas para resposta a incidente;
- Controles de mitigação;
- Ferramentas de monitoramento e planos estratégicos para gestão dos incidentes;
- Identificação de ameaças como framework de ataque *Cyber Kill Chain* e o Modelo MITRE ATT&CK.

Aula 03

Resposta a incidentes e protocolos seguros

Lidando com Incidentes —



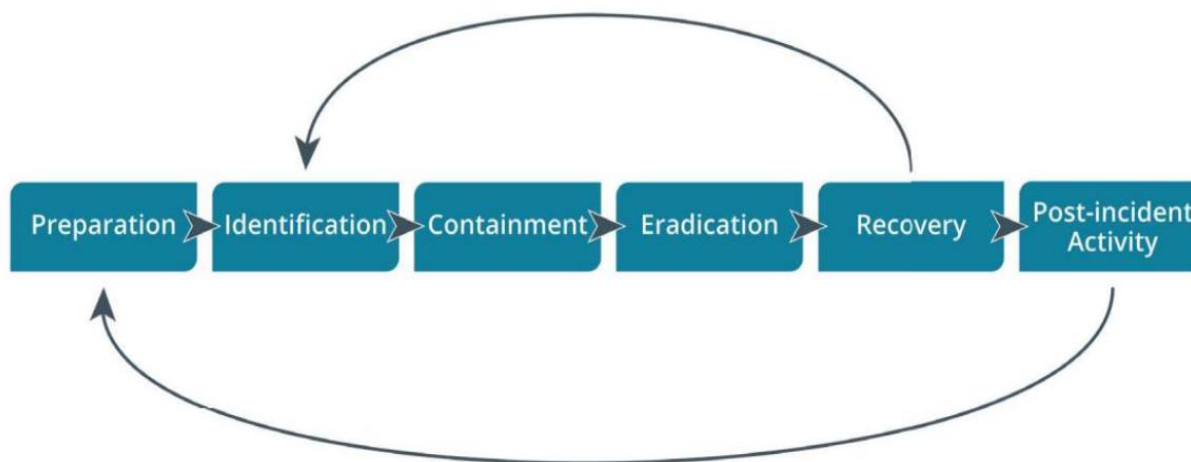
Processo de Resposta a Incidentes

- A política de resposta a incidentes define os recursos, processos e diretrizes para lidar com incidentes de segurança.
- A resposta a incidentes segue um processo bem estruturado com etapas bem definidas.
- O objetivo é identificar, conter, mitigar e aprender com incidentes a fim de evitar danos à imagem da organização.

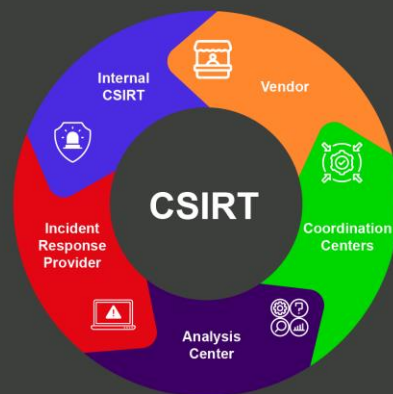
Processo de Resposta a Incidentes

— Etapas do processo de resposta a incidentes:

- Preparação;
- Identificação;
- Contenção;
- Erradicação;
- Recuperação;
- Lições Aprendidas.



COMPUTER SECURITY INCIDENT RESPONSE TEAM (CSIRT) Categories of CSIRTs



Fonte: Collidu.
Disponível em: <<https://www.collidu.com/presentation-computer-security-incident-response-team-csirt>>.
Acesso em: 18 mar. 2024.

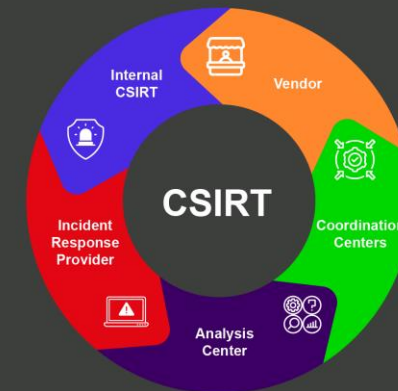
Computer Security Incident Response Team (CSIRT)

- Trata-se da equipe de profissionais especializados responsáveis por gerenciar e coordenar internamente a resposta a incidentes na organização.
- O CSIRT tem as seguintes funções:
 - Coordenação e gerenciamento atuando como um *single point-of-contact*;
 - Deteção e análise por meio de monitoramento da rede e dos sistemas.

Computer Security Incident Response Team (CSIRT)

- O CSIRT tem as seguintes funções: (cont.)
 - Investigação e resposta conforme a extensão do incidente;
 - Comunicação e notificação aos *stakeholders*;
 - Mitigação e prevenção;
 - Melhoria contínua incluindo reavaliação dos planos de resposta a incidentes.

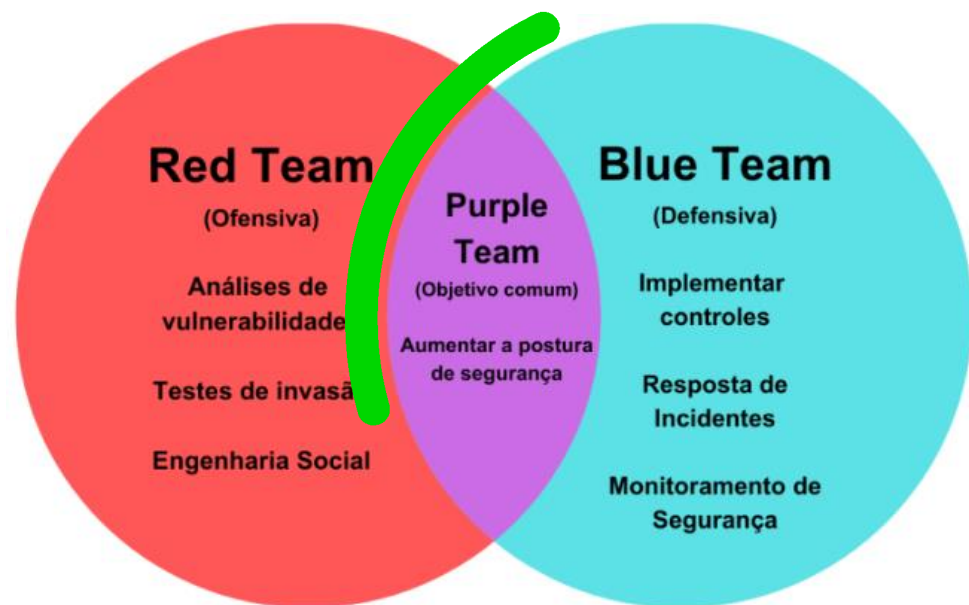
COMPUTER SECURITY INCIDENT RESPONSE TEAM (CSIRT) Categories of CSIRTs



Fonte: Collidu.

Disponível em: <<https://www.collidu.com/presentation-computer-security-incident-response-team-csirt>>.

Acesso em: 18 mar. 2024.



Fonte: CLEANCLOUD.

Disponível em: <<https://cleancloud.io/quais-as-diferencas-entre-red-team-blue-team-e-purple-team/>>.

Acesso em: 18 mar. 2024.

Times de segurança da informação

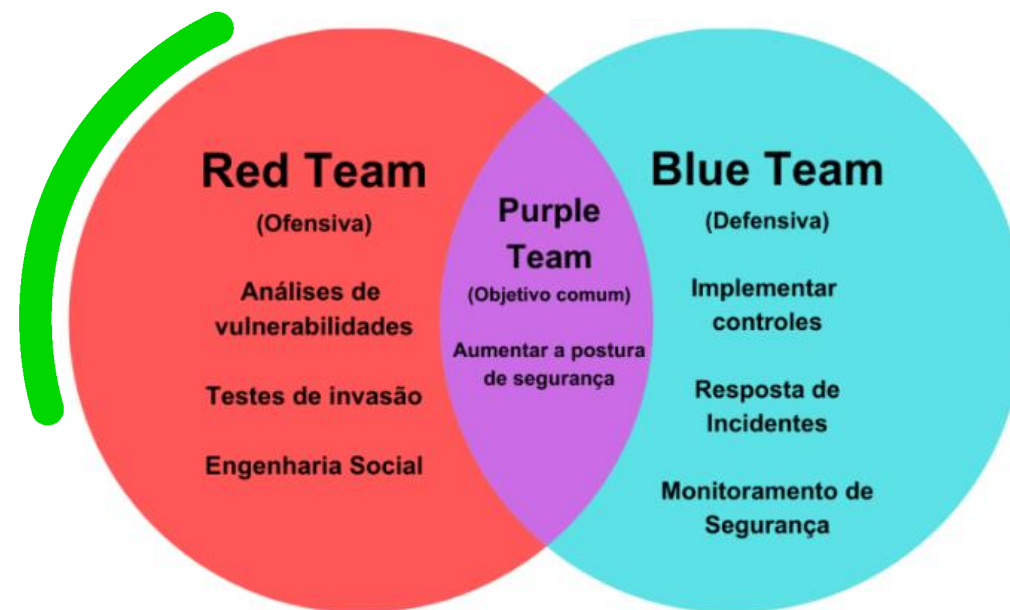
Blue Team

- Grupo operacional que trabalha na implantação das medidas de segurança;
- Monitora a infraestrutura, detecta e responde a incidentes de segurança;
- Executa a configuração dos dispositivos como firewall, IDS, IPS, etc;
- Executa a configuração dos dispositivos como firewall, IDS, IPS, etc.

Times de segurança da informação

— Red Team

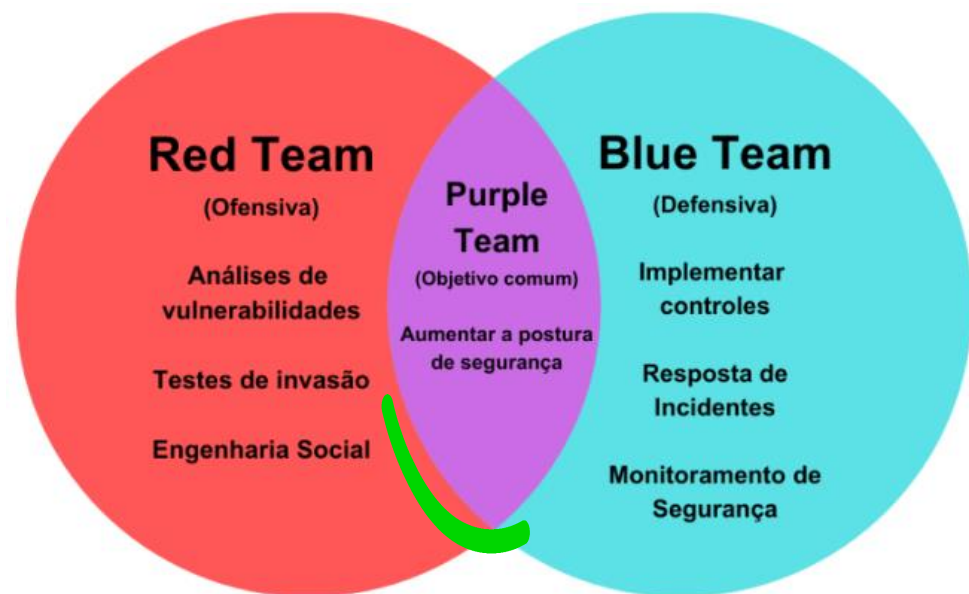
- Grupo operacional que Trabalha na prevenção;
- Simula ataques cibernéticos para identificar possíveis vulnerabilidades;
- Realizam testes de penetração;
- Realizam tentativas de invasão aos sistemas com controle e ética.



Fonte: CLEANCLOUD.

Disponível em: <<https://cleancloud.io/quais-as-diferencas-entre-red-team-blue-team-e-purple-team/>>.

Acesso em: 18 mar. 2024.



Fonte: CLEANCLOUD.
Disponível em: <<https://cleancloud.io/quais-as-diferencas-entre-red-team-blue-team-e-purple-team/>>.
Acesso em: 18 mar. 2024.

Times de segurança da informação

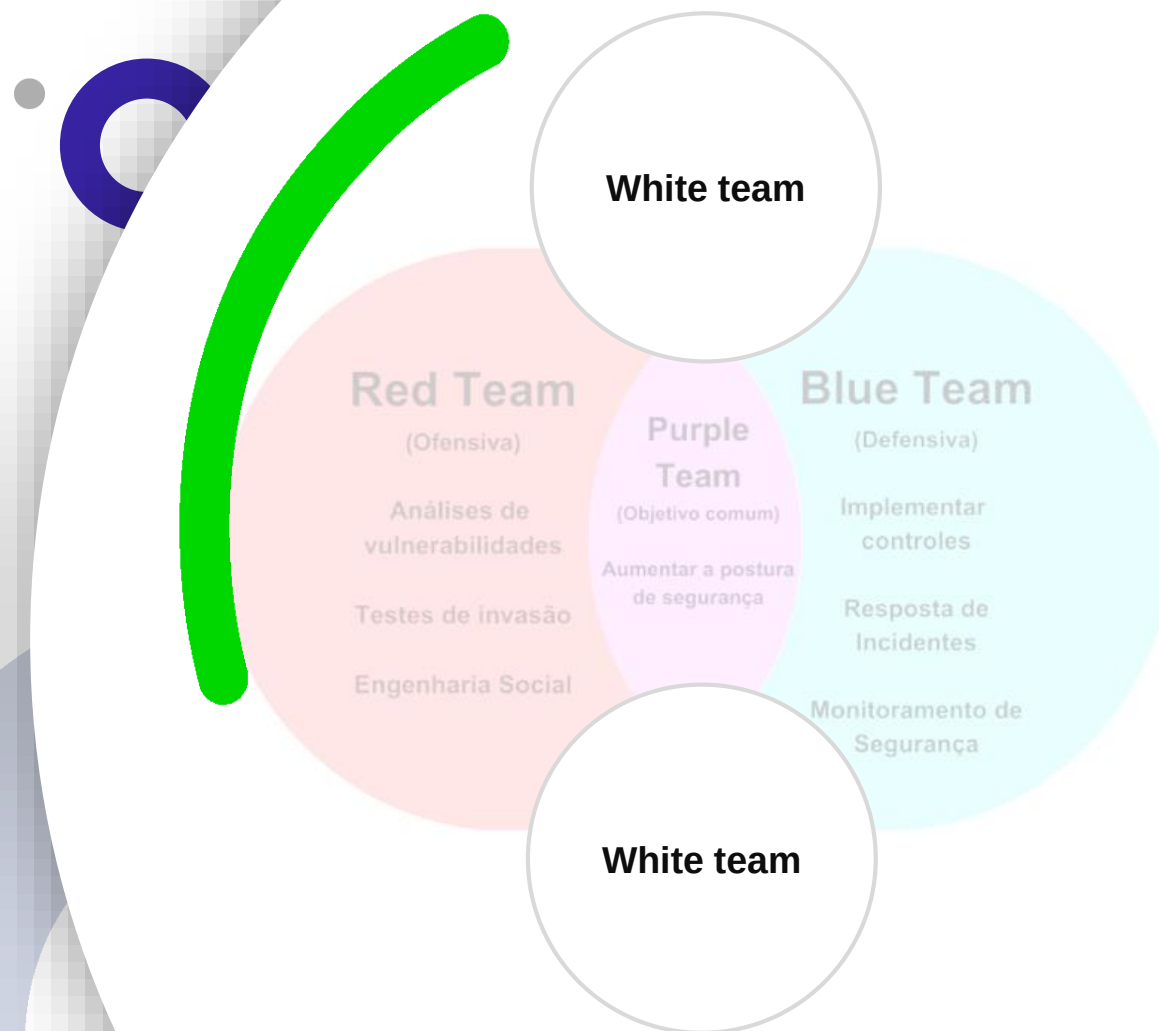
— Purple Team

- Trabalha em conjunto com o *Blue* e *Red Team*;
- Coordena e planeja ações conjuntas entre o *Blue* e *Red Team*;
- Compartilha informações entre as equipes;
- Avalia e mede a eficiência e efetividade dos controles de segurança;
- Promove a cultura de melhoria contínua dos processos de resposta a incidentes.

Times de segurança da informação

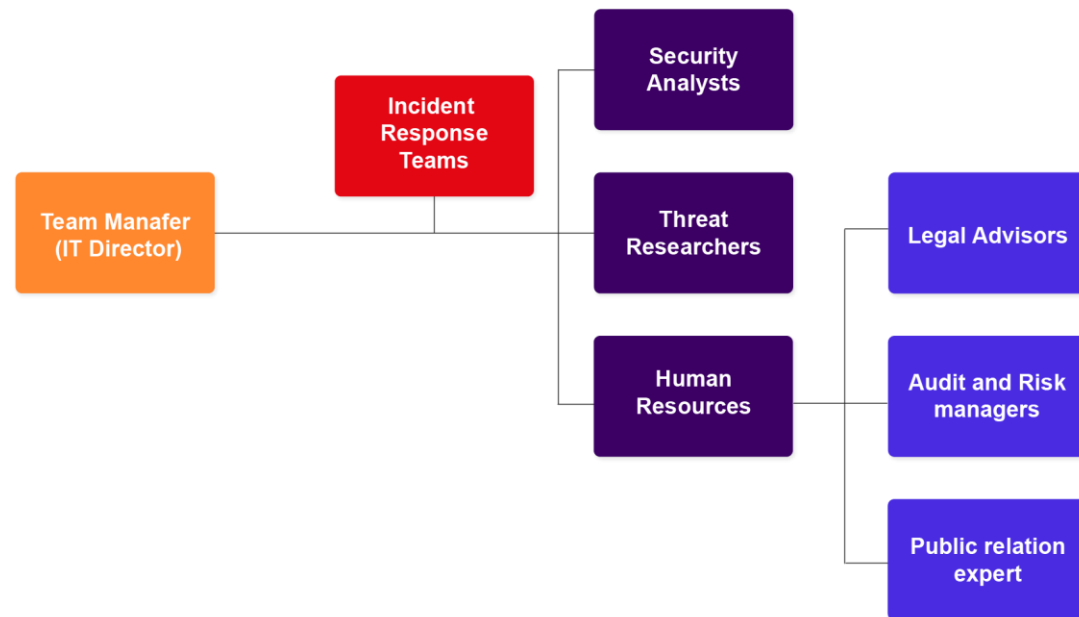
White Team

- Grupo seguidamente ligado a competições de *cyber security* como CTFs;
- Trabalha na criação de cenários, desafios e ambientes de teste;
- Atuam na organização das competições;
- Podem atuar como juiz na determinação da pontuação dos competidores.



Fonte: CLEANCLOUD.
Disponível em: <<https://cleancloud.io/quais-as-diferencas-entre-red-team-blue-team-e-purple-team/>>.
Acesso em: 18 mar. 2024.

Incident Response Teams



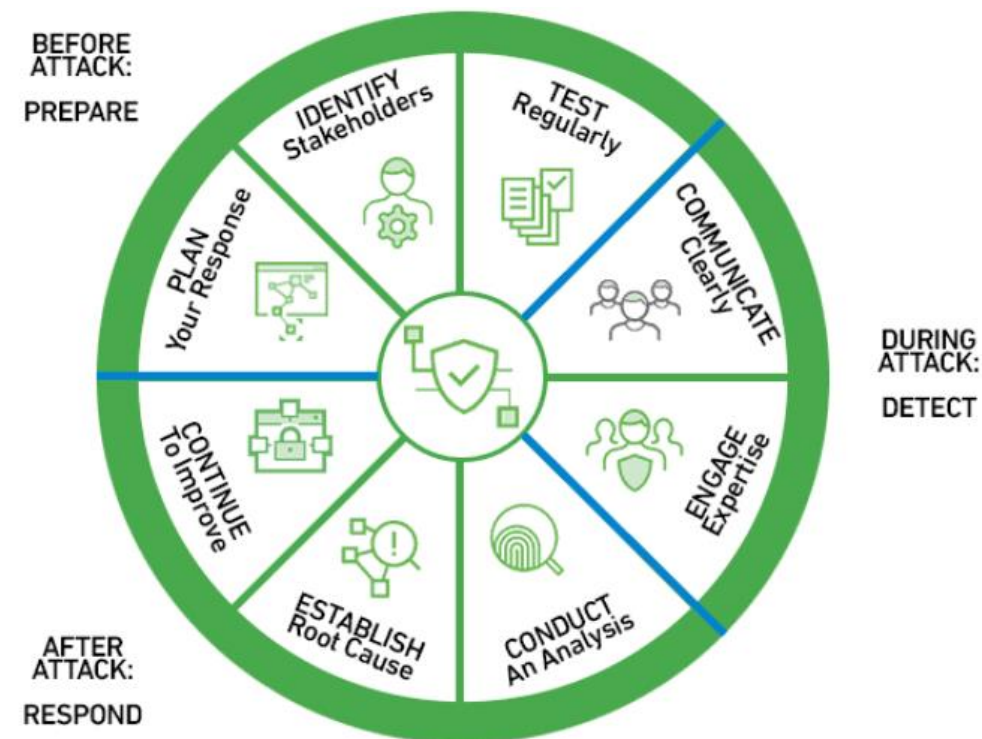
Fonte: Software testing help.
Disponível em: <<https://www.softwaretestinghelp.com/what-is-incident-response-plan/>>.
Acesso em: 18 mar. 2024.

Plano de Resposta a Incidentes - *Incident Response Plan (IRP)*

- Um IRP contém a lista dos procedimentos, contatos e recursos disponíveis para várias categorias de incidentes.
- São essas orientações que guiarão os investigadores na determinação de prioridades e planos de remediação.
- Um IRP deve conter:
 - Objetivos e escopo;
 - Equipe (Time de especialistas) e papéis.

Plano de Resposta a Incidentes - *Incident Response Plan (IRP)*

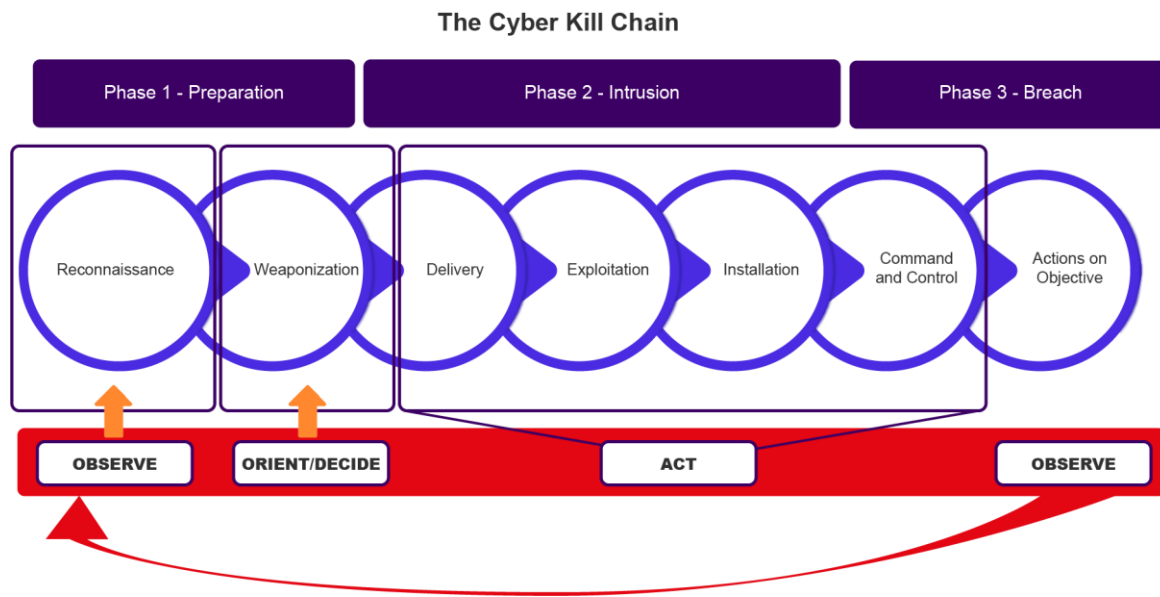
- Classificação e priorização;
- Fases de resposta;
- Procedimentos específicos;
- Comunicação e notificação;
- Cooperação externa;
- Testes e atualizações;
- Treinamento e conscientização.



Fonte: Exabeam.

Disponível em: <<https://www.exabeam.com/incident-response/incident-response-plan/>>.

Acesso em: 18 mar. 2024.



Fonte: Oreilly.
Disponível em: <<https://www.oreilly.com/library/view/practical-cyber-intelligence/9781788625562/57958656-3d88-4734-bc32-bf2d35b7c3e9.xhtml>>.
Acesso em: 18 mar. 2024.

Cyber Kill Chain Attack Framework

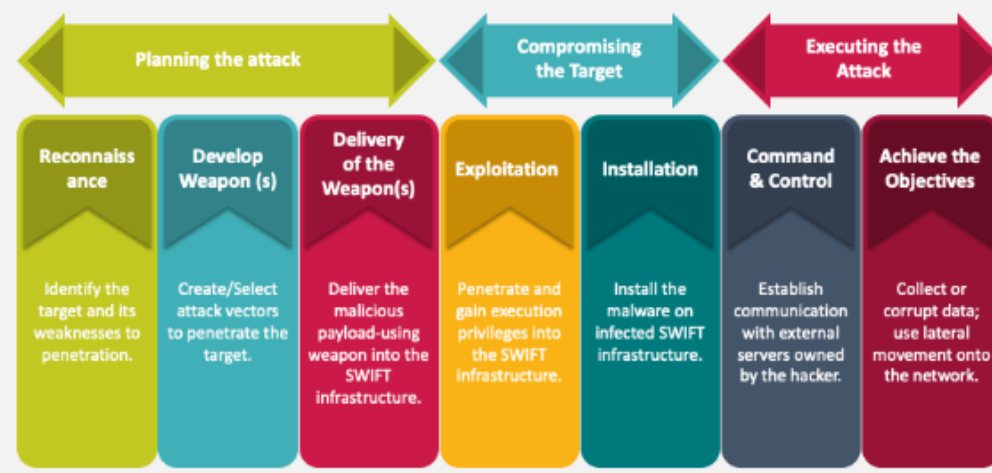
- É uma estrutura utilizada para descrever os estágios de um cyber attack.
- Descreve as etapas geralmente seguidas pelos atacantes cibernéticos.
- É uma ferramenta chave para a pesquisa de ameaças fornecendo insights sobre táticas, técnicas e procedimentos (TTPs) do adversário.

Cyber Kill Chain Attack Framework

- Etapas do *Cyber Kill Chain*:
 - Reconhecimento;
 - Armadilha (*Weaponization*);
 - Entrega;
 - Exploração (*Exploitation*);
 - Instalação;
 - Comando e Controle (C2);
 - Ação (*Action on Objectives*).

CYBER KILL CHAIN

Cyber Kill Chain Activities



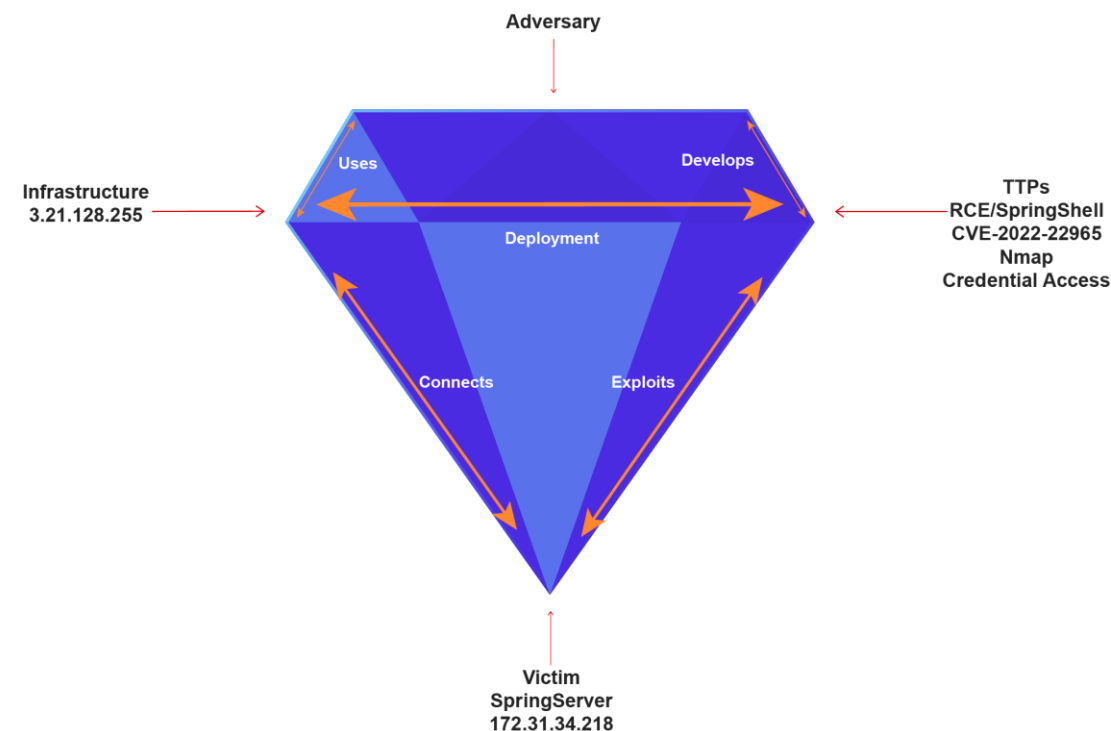
Fonte: Colidu.

Disponível em: <<https://www.collidu.com/presentation-cyber-kill-chain>>.

Acesso em: 18 mar. 2024.

Modelo Diamante de Análise de Intrusão

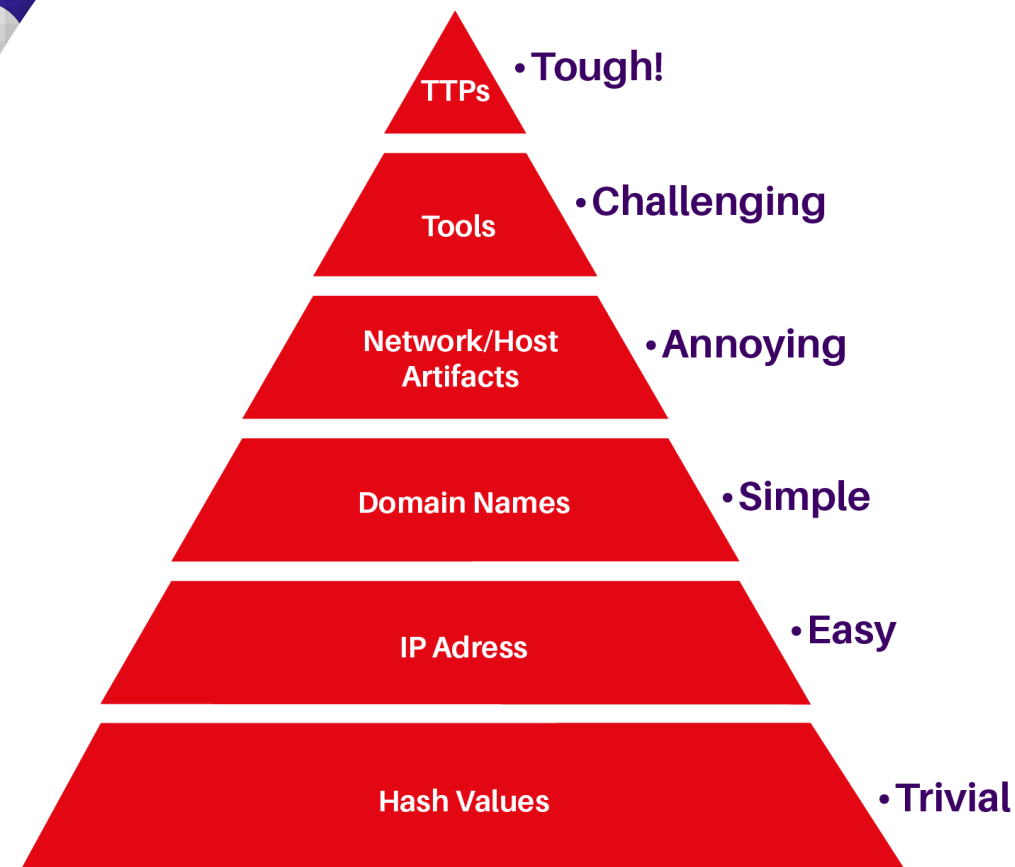
- Também conhecido como *The Diamond Model of Intrusion Analysis*.
- Auxilia conceitualmente na análise mais profunda de um ataque cibernético.
- A visualização gráfica do modelo tem a forma de um diamante composto de quatro principais componentes:
 - Adversário (*Adversary*);
 - Infraestrutura (*Infrastructure*);
 - Capacidade (*Capability*);
 - Vítima (*Victim*).



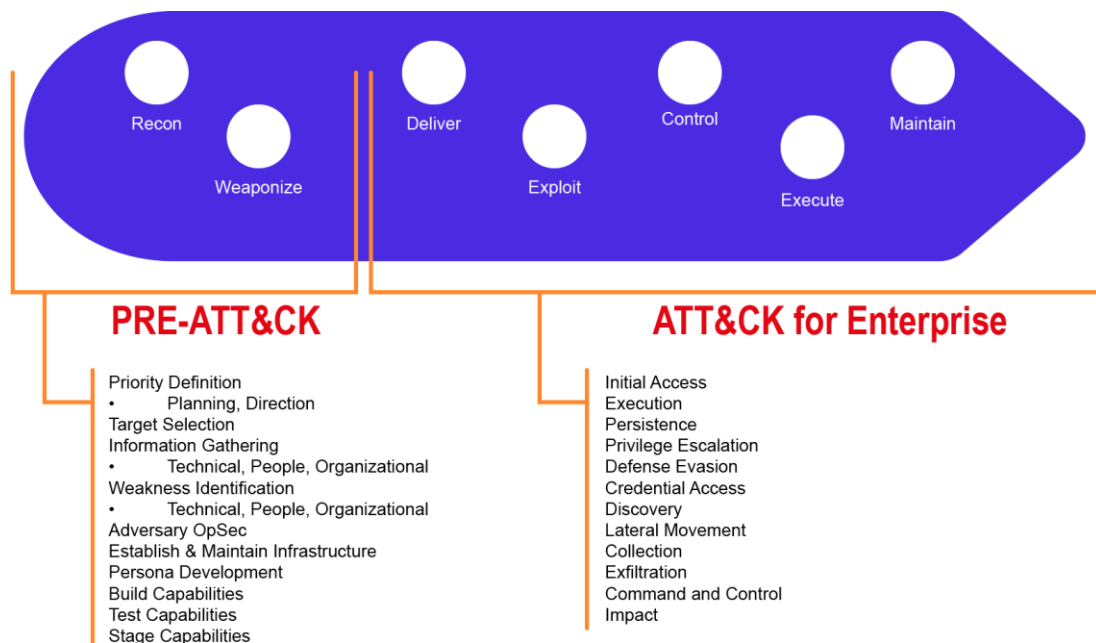
Fonte: Michaelkoczwar.
Disponível em: <<https://michaelkoczwar.medium.com/diamond-model-of-intrusion-analysis-in-practice-31659f370043>>.
Acesso em: 18 mar. 2024.

MITRE ATT&CK

- Adversarial Tactics, Techniques, and Common Knowledge é mais uma estrutura que detalha as táticas, técnicas e procedimentos (TTPs) dos cyber attacks.
- Visa o aprimoramento de defesas pelas organizações.
- O framework possui os seguintes recursos:
 - Matriz de Táticas e Técnicas;
 - Táticas;
 - Técnicas;
 - Frameworks de Ataque.



Fonte: Michaelkoczwar. Disponível em: <<https://michaelkoczwar.medium.com/diamond-model-of-intrusion-analysis-in-practice-31659f370043>>. Acesso em: 18 mar. 2024.



Fonte: Medium.

Disponível em: <<https://ensarseker1.medium.com/mitre-pre-att-ck-db744fe719ed>>.

Acesso em: 18 mar. 2024.

MITRE ATT&CK

- O framework possui os seguintes recursos (cont.):
 - Detecção e prevenção;
 - Treinamento e conscientização;
 - Teste de *Red Team*;
 - Análise de incidentes.

Exercícios de Resposta a Incidentes

- São atividades realizadas pelas organizações visando a otimização dos processos de resposta a incidentes.
- Há três tipos principais:
 1. *Tabletop Exercise* (Exercício de Mesa Redonda);
 - Processo;
 - Benefícios.



Exercícios de Resposta a Incidentes

2. *Walkthrough Exercise* (Exercício de Passo a Passo):

- Processo;
- Benefícios.

3. *Simulation Exercise* (Exercício de Simulação):

- Processo;
- Benefícios.



Plano de Recuperação de Desastres

- O *Disaster Recovery Plan* (DRP) é um documento que reúne procedimentos e estratégias para recuperação do ambiente diante de desastres.
- Visa o retorno a normalidade operacional o mais rápido possível.
- O DRP deve conter:
 - Identificação de ativos críticos;
 - Avaliação de riscos e impacto;
 - Definição de objetivos de recuperação.



Fonte: Uellington Santos.

Disponível em:

<<https://pt.linkedin.com/pulse/recupera%C3%A7%C3%A3o-de-desastres-parte-3-o-plano-uellington-santos>>.

Acesso em: 18 mar. 2024.

Plano de Recuperação de Desastres

- O DRP deve conter:
 - Estratégias de recuperação;
 - Procedimentos de recuperação;
 - Alocação de recursos;
 - Testes e treinamento;
 - Manutenção e atualização;
 - Comunicação e notificação;
 - Revisão e melhoria contínua.

Plano de Continuidade de Negócios

- O *Business Continuity Plan* (BCP) é um documento que reúne estratégias, processos e procedimentos necessários para garantir a continuidade das operações de negócio.
- Visa minimizar os efeitos negativos de eventos de grande impacto assegurando a sobrevivência da organização.
- O BCP deve conter:
 - Identificação de funções essenciais;
 - Avaliação de riscos e impactos;



Fonte: Burnie Group.
Disponível em: <<https://burniegroup.com/top-10-priorities-for-a-strong-business-continuity-plan/>>.
Acesso em: 18 mar. 2024.



Fonte: Burnie Group.
Disponível em: <<https://burniegroup.com/top-10-priorities-for-a-strong-business-continuity-plan/>>.
Acesso em: 18 mar. 2024.

Plano de Continuidade de Negócios

- O BCP deve conter (cont.):
 - Definição de objetivos de continuidade;
 - Estratégias de continuidade;
 - Plano de ação;
 - Testes e treinamento;
 - Manutenção e atualização;
 - Comunicação e notificação;
 - Revisão e melhoria contínua.

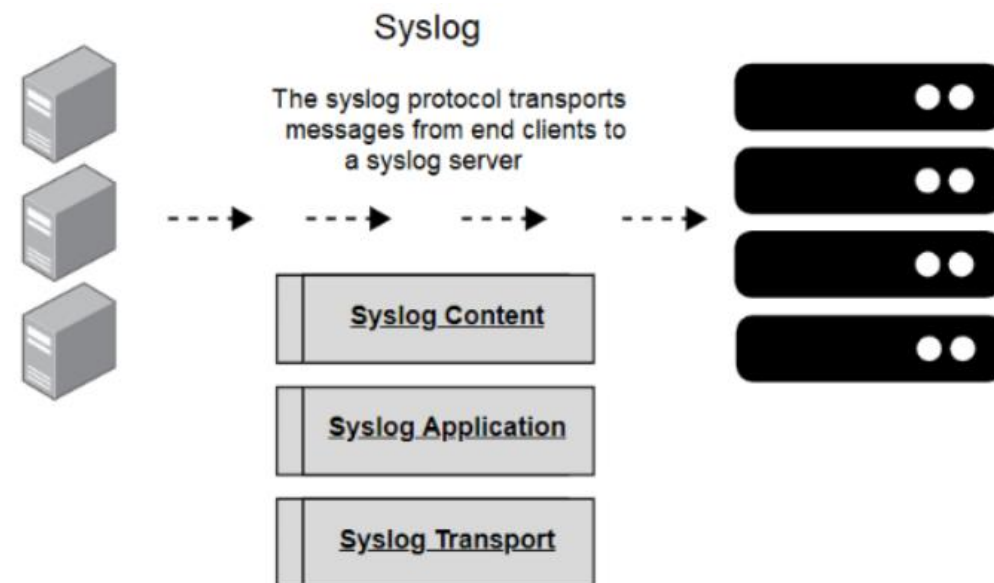
Aula 03

Resposta a incidentes e protocolos seguros

Ferramentas de respostas a incidentes —

Plataformas de Registro

- São ferramentas utilizadas na coleta, armazenamento e análise de registros de logs gerados pelos diversos elementos da infraestrutura de TI.
- Cada *_logging platforms_* tem características próprias.
- Tipos de plataformas mais utilizados:
 - Syslog;
 - Rsyslog;
 - Syslog-ng;
 - Journalctl;
 - Nxlog.

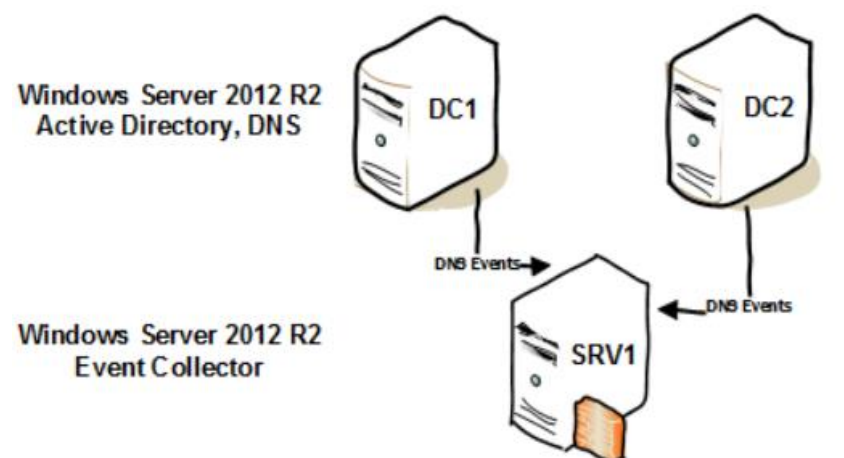


Fonte: CrowdStrike.

Disponível em:

<<https://www.crowdstrike.com/guides/syslog-logging/>>.

Acesso em: 18 mar. 2024.



Fonte: Skufel.

Disponível em: <<https://blog.skufel.net/tag/windows-server/>>.

Acesso em: 18 mar. 2024.

Os Application Log Files fornecem informações sobre o comportamento e a atividade de aplicativos, sistemas e serviços.

- Os *Application Log Files* fornecem informações sobre o comportamento e a atividade de aplicativos, sistemas e serviços.
- Os registros de aplicativos podem ser:
 - *DNS Event Logs* (Registros de Eventos DNS);
 - Consulta de DNS (DNS Query);
 - Registro de resposta (DNS Response);
 - Análise de padrões e anomalias.

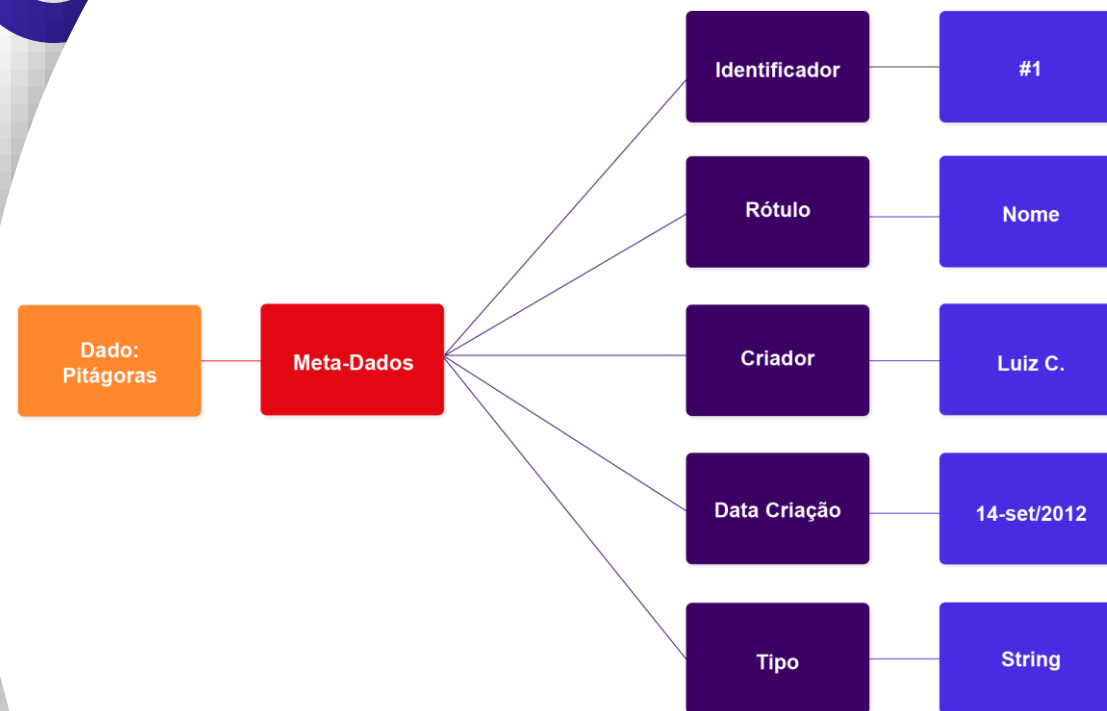
Registros de Aplicativos

- Web/HTTP Access Logs
(Registros de Acesso a Sites e HTTP):
 - Solicitações de acesso;
 - Respostas do servidor;
 - Detecção de atividades maliciosas;
 - Monitoramento de desempenho.

```
127.0.0.1 - [29/oct/2010 : 10:29:37 +0330] "Get /xampp/ HTTP/1.1" 302 - "-" "Opera/9.50 (Windows NT 5.1; U; en)"
127.0.0.1 - [29/oct/2010 : 10:29:37 +0330] "Get /xampp/ HTTP/1.1" 200 6545 "http://localhost/xampp/splash.php"
127.0.0.1 - [29/oct/2010 : 10:29:37 +0330] "Get /xampp/ HTTP/1.1" 200 6338 "http://localhost/xampp/splash.php"
127.0.0.1 - [29/oct/2010 : 10:29:41 +0330] "Get /xampp/ HTTP/1.1" 200 4357 "http://localhost/xampp/splash.php"
127.0.0.1 - [29/oct/2010 : 10:29:41 +0330] "Get /xampp/ HTTP/1.1" 302 - "-" "http://localhost/xampp/Opera/9.50 (Windows NT 5.1;)"
127.0.0.1 - [29/oct/2010 : 10:29:41 +0330] "Get /xampp/ HTTP/1.1" 302 - "-" ""http://localhost/xampp/splash.php"
127.0.0.1 - [29/oct/2010 : 10:29:41 +0330] "Get /xampp/ HTTP/1.1" 200 4383 "http://localhost/xampp/splash.php"
```

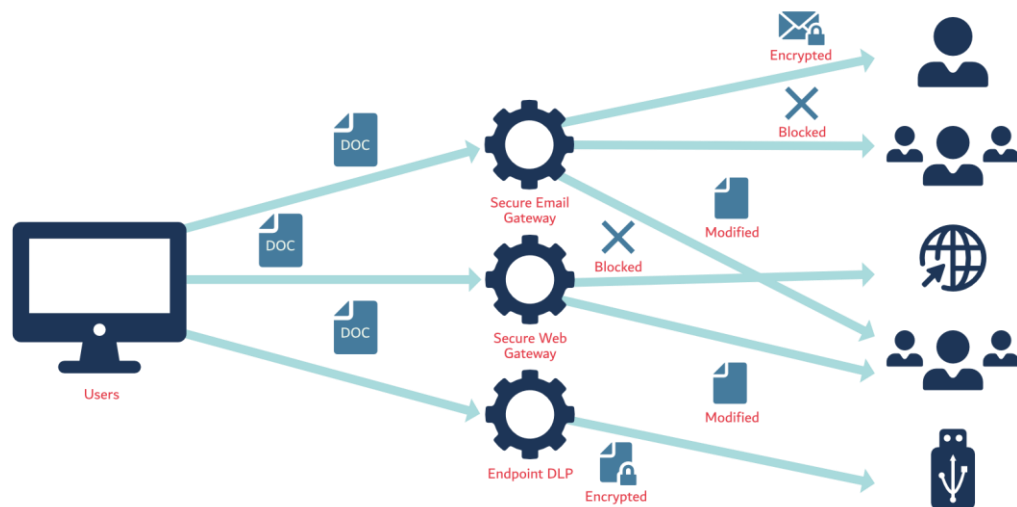
Metadados

- Metadados fornecem informações de outros dados subjacentes.
- Facilitam a compreensão e o gerenciamentos desses dados.
- Podem ser encontrados de várias formas:
 - Metadados de arquivo;
 - Metadados da Web;
 - Metadados de E-mail;
 - Metadados móveis.



Metadados de um Dado

Fonte: Luiz Camolesi.
Disponível em: < <https://www.linkedin.com/pulse/metadados-conceitos-b%C3%A1sicos-luiz-camolesi-jr-/?originalSubdomain=pt>>.
Acesso em: 18 mar. 2024.



Fonte: Cielhr.

Disponível em: <<https://www.cielhr.com/prevent-data-loss-by-outsourcing-your-employees/>>.

Acesso em: 18 mar. 2024.

Prevenção de Perda de Dados (*Data Loss Prevention – DLP*)

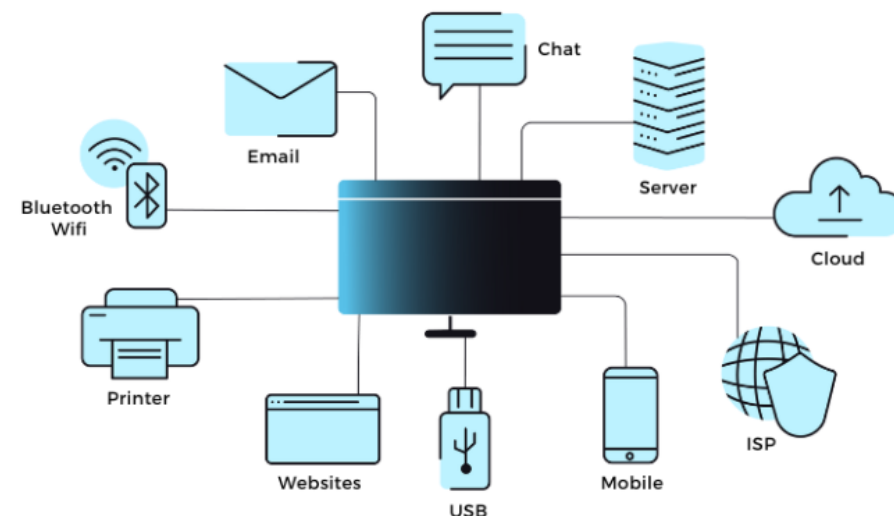
- Agrega uma estratégia e conjunto de tecnologias com foco na proteção de dados sensíveis e confidenciais.
- Visa proteger dados confidenciais contra ameaças internas e externas.

Prevenção de Perda de Dados (*Data Loss Prevention – DLP*)

■ Etapas do funcionamento

- Identificação de dados sensíveis;
- Monitoramento de tráfego e atividades;
- Detecção de conteúdo sensível;
- Política de ação;
- Prevenção e correção;
- Auditoria e relatórios.

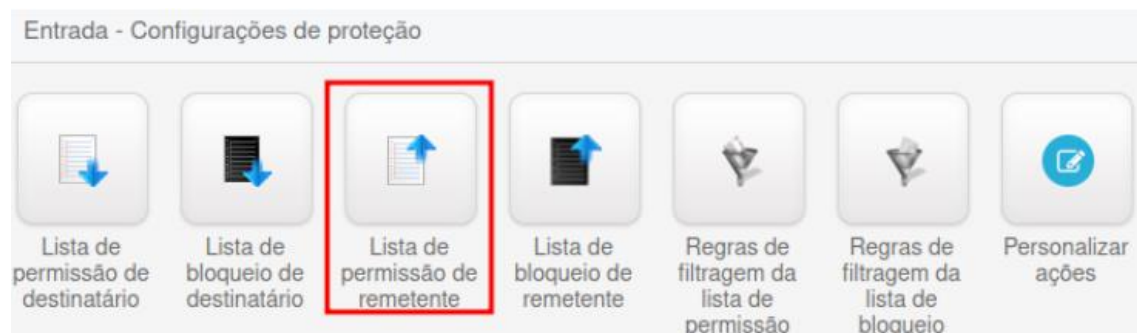
DLP IS A NEVER ENDING CHALLENGE



Fonte: LUXSCI.

Disponível em: <<https://luxsci.com/blog/futureproof-your-data-loss-prevention-strategy.html>>.

Acesso em: 18 mar. 2024.



Fonte: Inetweb

Disponível em: < <https://ajuda.inetweb.com.br/kb/adicionando-enderecos-a-lista-permissao-de-remetente-antispam/>>.

Acesso em: 18 mar. 2024.

Listas de permissão e de bloqueio

- Listas de permissão (*Allow Lists*) e listas de bloqueio (*Block Lists*)
Procedimentos para a entrevista controlam quais aplicativos tem autorização para serem executados.
- Visa proteger contra execução de aplicativos maliciosos ou acesso a conteúdo potencialmente prejudicial.

Listas de permissão e de bloqueio

- *Application Allow Lists* – Contém a lista de aplicativos autorizados.
- Funcionamento:
 - Criação da lista;
 - Bloqueio de Aplicativos Não Autorizados;
 - Prevenção de Execução de *Malware*.



Listas de permissão e de bloqueio

- *Application Allow Lists* –
Contém a lista de aplicativos não confiáveis ou inseguros. Visa o impedimento da execução desses aplicativos.
- Funcionamento:
 - Criação da lista;
 - Impedindo a Execução de Aplicativos Bloqueados;
 - Prevenção de Ameaças Conhecidas.

12



Você chegou ao final da Aula 03
Resposta a Incidentes